

SENTINELX

AI-Powered OWASP Top 10 Security Assessment Report

Target Evaluated:	https://localhost:3000
Assessment Date:	2026-09-09 10:00:00
Overall Risk Score:	75.0 / 100
Total Findings:	1
Assessment Type:	Automated Web VAPT & SAST (website)
Classification:	CONFIDENTIAL - SECURITY ASSESSMENT

Confidentiality Notice: This document contains proprietary and confidential vulnerability details obtained during authorized educational and diagnostic penetration testing. Unauthorized distribution is prohibited.

1. Executive Summary

A comprehensive automated security assessment was performed against **https://localhost:3000** using the SentinelX VAPT Workstation. The system evaluated the target's attack surface against the OWASP Top 10 Web Application Security standard, identifying a total of **1 findings** resulting in a consolidated Risk Score of **75.0/100**.

Severity Level	Finding Count	Impact Description
Critical	1	Immediate threat of total system compromise or data breach
High	0	High probability of unauthorized access, injection, or data loss
Medium	0	Significant configuration or access control weakness
Low	0	Minor information leakage or suboptimal security practices
Informational	0	Reconnaissance data and contextual service metrics

2. Assessment Scope

Primary Target: https://localhost:3000
Scan Mode: website
Crawler Depth: 2
Execution Mode: Local Non-Destructive Vulnerability Assessment

3. Testing Methodology

SentinelX utilizes a multi-phase testing framework aligned with the OWASP Testing Guide (OTG v4) and NIST SP 800-115:

- Passive & Active Reconnaissance:** Crawling domain boundaries, extracting input vectors, fingerprinting stacks.
- Vulnerability Verification:** Heuristic probing of SQL injection, XSS reflection & DOM sinks, IDOR access bounds, and cookie flags.
- Static Source Code Analysis (SAST):** In-depth AST and pattern scanning for hardcoded secrets and dangerous sinks.
- Threat Intelligence Correlation:** Cross-referencing domains and IPs against VirusTotal, AbuseIPDB, and NIST CVE databases.

4. Reconnaissance Results

Total Discovered Endpoints: 0
Discovered Form Inputs: 0

5. Technology Stack Fingerprint

Detected Technologies: Generic HTTP Web Server / Standard Web Application

6. Threat Intelligence Correlation

Threat intelligence enrichment queries VirusTotal, AbuseIPDB, and Shodan to identify historical domain reputation, malicious activity reports, and exposed ports.

7. Detailed OWASP Top 10 Findings

Finding #1: SQL Injection in /api/users	[CRITICAL] - CVSS 9.8
OWASP Category: A03:2021-Injection Target Endpoint: https://localhost:3000/api/users Vulnerable Parameter: id Description: Payload Used: ' OR '1'='1 Evidence: MySQL error Remediation: Use prepared statements	

8. Payloads & HTTP Evidence Summary

All active probing was performed using standardized non-destructive payload sets designed to reveal reflection, syntax errors, and authorization anomalies without modifying persistent records.

9. CVE & CWE Mapping

Vulnerabilities are mapped to standard Common Weakness Enumeration (CWE) and Common Vulnerabilities and Exposures (CVE) definitions for enterprise compliance reporting.

10. Remediation Roadmap & Best Practices

1. **Prioritize Critical/High Vulnerabilities:** Address SQL injection via parameterized queries and implement object-level authorization checks.
2. **Harden Security Headers:** Implement Content-Security-Policy (CSP), Strict-Transport-Security (HSTS), and anti-clickjacking headers.
3. **Secure Session Storage:** Ensure all session cookies have HttpOnly, Secure, and SameSite=Lax flags enabled.
4. **Secrets Hygiene:** Remove any exposed API keys from frontend bundles and move them to secure backend vaults.

11. Appendix & Assessment Tool Details

Report generated by **SentinelIX v1.0** — Local AI-Powered OWASP Top 10 VAPT Suite.
Assessment Engine: Python FastAPI, SQLAlchemy, BeautifulSoup4, ReportLab.
Standards: OWASP Top 10:2021, NIST SP 800-115, CWE/SANS Top 25.